

Implementação e utilização de uma PKI Local

Os certificados digitais de chave pública, normalmente designados apenas por certificados, são uma peça fundamental para o estabelecimento de confiança na utilização da criptografia assimétrica (também designada por criptografia de chave pública). O grande problema deste tipo de criptografia é saber quem é a entidade (pessoa ou outro tipo de entidade) dona de uma chave pública. Em comunicações isto é crítico para impedir ataques man-in-the-middle e na assinatura digital de documentos é crítico para verificar a autenticidade dos documentos assinados.

Um certificado digital associa uma identidade a uma chave pública, i.e., identifica a entidade dona dessa chave pública e, por consequência, a entidade dona da correspondente chave privada. Os certificados são emitidos e assinados por CAs, Entidades Certificadoras (CA - Certification Authorities), de acordo com determinadas políticas, após confirmarem a identidade do dono da chave pública e que este está efetivamente na posse da correspondente chave privada. As CAs, em conjunto com os certificados, as políticas de certificação e revogação, e eventuais outras entidades como as RA (Entidades de Registo) e as VA (Entidades de Validação), constituem o que se designa como uma Infraestrutura de Chave Pública (PKI – Public Key Infrastructure).

Uma CA possui um par de chaves e um certificado digital para a sua chave pública. Numa PKI pode haver várias CAs, que se organizam de forma hierárquica, formando uma hierarquia de confiança. No topo da hierarquia de confiança está uma CA cujo certificado é auto-assinado, i.e., assinado por ela própria. Este certificado auto-assinado designa-se por raiz de confiança. Os sistemas operativos e algumas aplicações (como o Firefox), trazem consigo um conjunto de certificados raiz de confiança nos quais confiam e nos quais o utilizador por inerência também confia, ao instalar e usar esses sistemas operativos e aplicações.

Uma hierarquia de certificados de uma PKI pode ter vários níveis. Como já referido, no topo da hierarquia está a CA raiz que apenas emite certificados para as CAs intermédias (também designadas como CA Subordinadas) do segundo nível da hierarquia. Em termos da Web, as PKI têm normalmente 3 níveis (não é obrigatório, podendo ter mais ou menos), sendo que no nível inferior (3º nível) estão os certificados emitidos para os servidores Web, que são emitidos pelas CA intermédias do 2º nível.

As PKI são vitais para a autenticação de serviços em toda a Internet. Elas são consideradas de confiança e essa confiança é herdada pelos certificados que as respetivas CAs emitem (assinam). Embora muitas PKI tenham uma abrangência global e sejam confiáveis à escala mundial, isso não é necessariamente uma exigência em todas as circunstâncias e podem existir PKI confiáveis numa menor escala. Se os utentes dos certificados emitidos, direta ou indiretamente, por uma dada CA local confiarem na sua operação e na correção da sua chave pública, então podem confiar nos certificados em cuja validação o certificado dessa CA surge como raiz de confiança.

1. Instalação do XCA

Para a realização deste trabalho iremos usar um sistema Ubuntu. Para a implementação das CAs, usaremos o software XCA, que pode ser instalado usando o comando apt (o pacote chama-se xca).

1.1 Criação e configuração da CA Raiz

O primeiro passo é iniciar a aplicação XCA e criar uma nova base de dados para a CA Raiz (root CA). Não se esqueça de especificar uma senha (que servirá para proteger dados secretos da CA, nomeadamente a sua chave privada que é usada para assinar os certificados que emite. Esta base de dados servirá também para guardar toda a informação usada na gestão corrente da CA.

Em seguida gere o certificado de raiz (auto-assinado), que será a raiz de confiança para a hierarquia de certificados desta PKI. Clique na aba “Certificates” e depois no botão “New Certificate”. Na aba “Source” da janela “Create X509 Certificate” (Figura 1) pode introduzir informação sobre como vai o novo certificado ser assinado (self-signed) e qual o modelo (template) de certificado (escolha o modelo CA). Depois clique no botão “Apply All”, o que irá aplicar ao novo certificado as extensões características de um certificado de uma CA. As extensões são campos que se incluem no certificado e servem vários fins, como por exemplo para indicar que operações podem ser realizadas com o certificado.

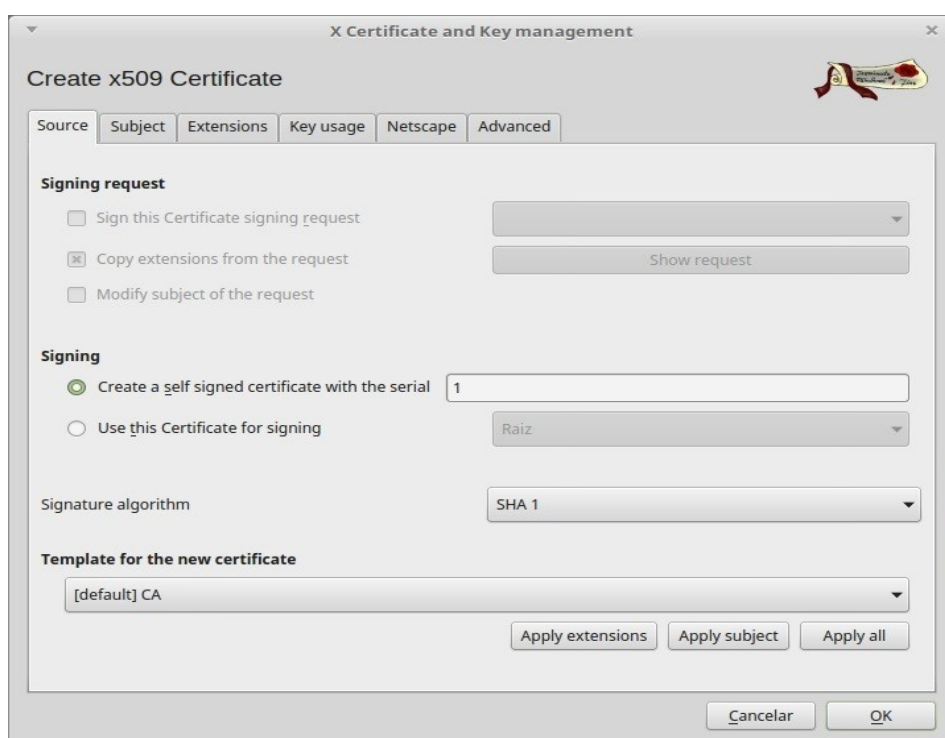


Figura 1: Criação de um certificado

De seguida clique na aba “Subject” onde irá fornecer os dados para a identificação da CA. Nesta introduza os dados para identificar a CA Raiz, tendo o cuidado de não introduzir espaços nem acentos. Pode inspirar-se nos dados observáveis na Figura 2 para identificar a sua CA Raiz.

Clique no botão “Generate a new key” para abrir a janela para gerar o par de chaves para a CA Raiz, que convém que seja robusta pelo que deve gerar uma de 4096 bits.

Na aba “Extensions” confirme nas “Basic Restrictions” que está selecionado o tipo “Certification Authority” e que são selecionadas as opções “Critical” e “Subject Key Identifier”, fundamentais para indicar que o certificado é o certificado de uma CA. Na aba “Key Usage” confirme que as opções “Certificate Sign” e “CRL Sign” estão selecionadas, e na aba Netscape confirme que as opções “SSL CA”, “S/MIME CA” e “Object Signing CA” estão selecionadas. Por fim, clique no botão “OK” para gerar o certificado. O certificado gerado pode agora ser visto na aba “Certificates” (Figura 3).

Explique o que é um certificado auto-assinado, por que razão o certificado da CA Raiz tem de ser um certificado auto-assinado.

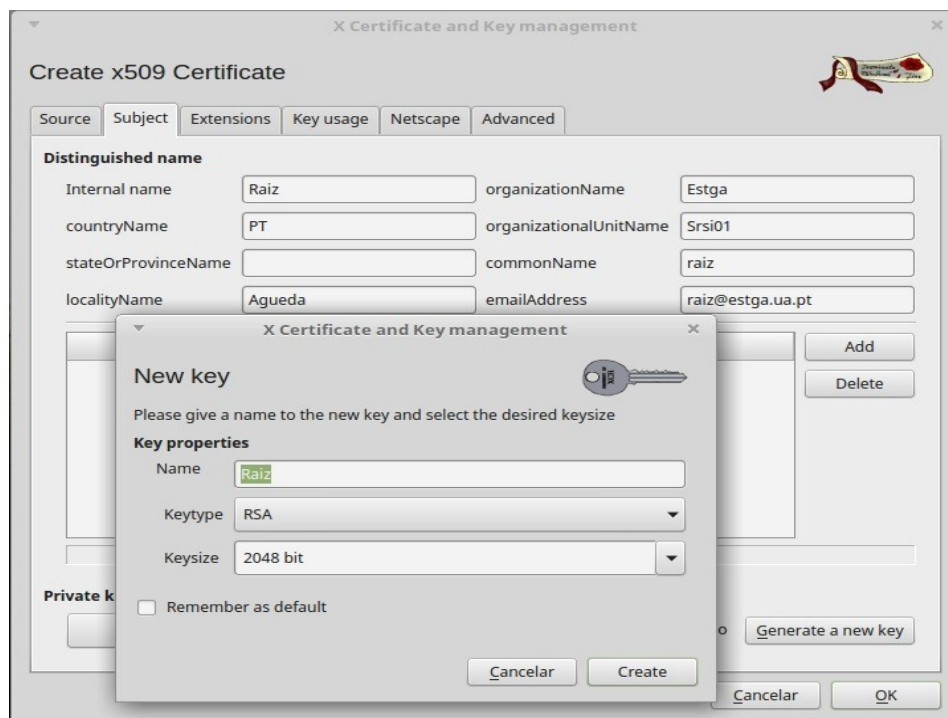


Figura 2: Identificação da CA Raiz e criação do seu par de chaves

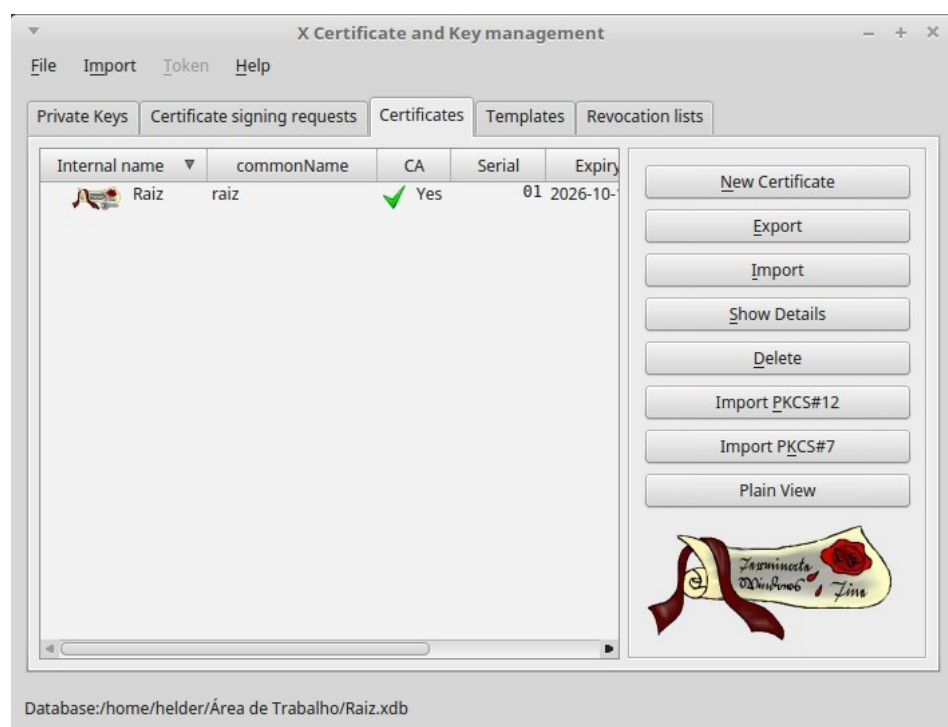


Figura 3: Certificado da CA Raiz

Explique o que é um certificado auto-assinado, por que razão o certificado da CA Raiz tem de ser um certificado auto-assinado.

2. Criação da CA Intermédia ou Subordinada

As CA Intermédias ou Subordinadas, usam-se para particionar a emissão de certificados e reduzir o risco em caso de eventual comprometimento de chaves privadas. Note que se a chave privada de uma CA Raiz for comprometida, todos os certificados na sua cadeia de certificados fica comprometida. Por essa razão, debaixo de uma CA Raiz normalmente usam-se várias CA Intermédias, cada uma para emitir certificados com um determinado propósito (por exemplo, uma para emitir certificados para alunos, outra para emitir os certificados para os docentes, etc.).

O primeiro passo é iniciar a aplicação XCA e criar uma nova base de dados para a CA Intermédia. Não se esqueça de especificar uma senha (que servirá para proteger dados secretos da CA, nomeadamente a sua chave privada que é usada para assinar os certificados que emite. Esta base de dados servirá também para guardar toda a informação usada na gestão corrente da CA.

3. Criação e exportação de um pedido de certificado

O certificado de uma CA Intermédia tem de ser assinado pela CA do nível hierarquicamente acima, que no nosso caso é a CA Raiz. Para esse efeito, temos de gerar um pedido de assinatura de certificado (*certificate signing request*). Este pedido deve conter todos os dados sobre a CA Intermédia que se pretende sejam colocados no seu certificado.

Para a criação do pedido de assinatura de certificado vá para a aba Certificate Signing Requests e prima o botão “New Request”, que abre a janela “X Certificate e Key Management” mostrada na figura 1.

Figura 4: Aba Source para a criação de um pedido de assinatura de certificado para uma CA.

Nesta janela, na Combo “Template for the new certificate”, selecione “[Default] CA” e depois pressione no botão “Apply All” para que o pedido seja talhado para um certificado de uma CA (sejam incluídas no certificado as extensões características de um certificado de uma CA).

De seguida clique na aba Subject. Nesta aba deve fornecer os dados que identificam a CA Intermédia. A figura 2 ilustra um exemplo que deve adaptar para a sua CA colocando o nome da sua CA no campo “CommonName”. Atenção que não são permitidos caracteres com acentos.

Figura 5: Aba Subject para a criação de um pedido de assinatura de certificado.

De seguida devemos gerar o par de chaves para a CA, pelo que deve premir o botão “Generate a new key”, que abre a janela da figura 3.

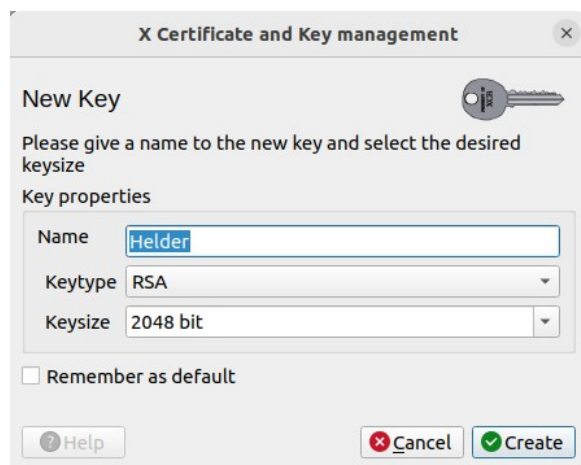


Figura 6: Janela para a criação de um par de chaves

Nesta janela informa-se um nome, o tipo e o tamanho para o par de chaves. Não precisa de alterar o que é sugerido. Clique no botão “Create” para criar o seu par de chaves e regressar à janela anterior.

Clique agora na aba “Extensions”. Esta aba, ilustrada na figura 4, indicam-se os valores para as extensões obrigatórias de um certificado. Algumas já vêm com os valores pré-preenchidos. No caso de a CA publicar listas de certificados revogados, deveria indicar o local da sua publicação no campo “X509v3 CRL Distribution Points”, o que não acontece neste caso. Procure na Web o significado de cada campo. Sem fazer alterações, clique na aba “Key Usage”.

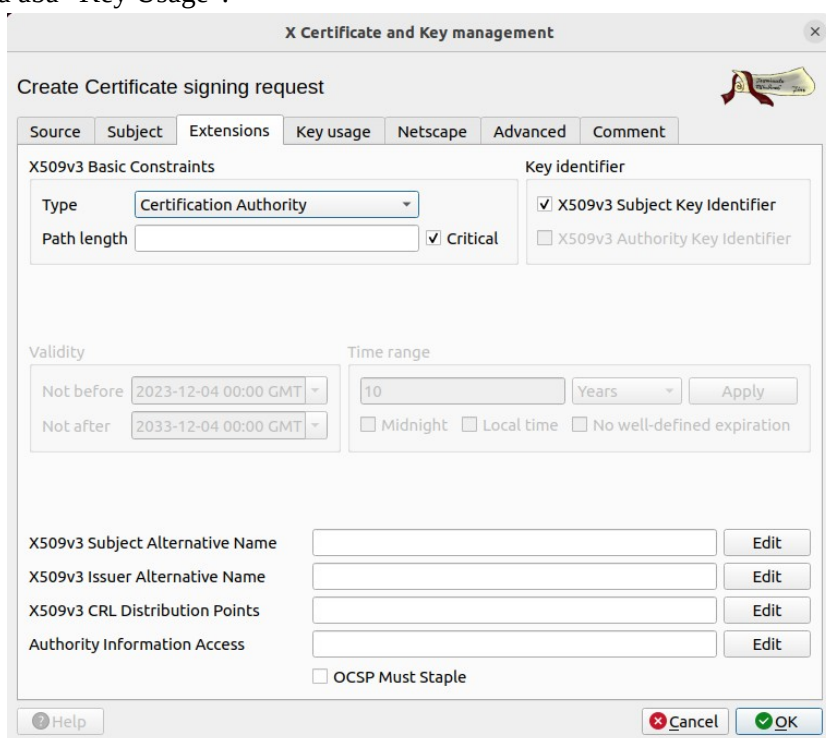


Figura 7: Aba Extensions para a criação de um pedido de assinatura de certificado para uma CA.

Na aba “Key Usage”, ilustrada na figura 5, indicam-se as utilizações permitidas para o certificado, que já vêm pré-selecionadas e não deve alterar. Deve apenas colocar a marca “Critical” do lado esquerdo da

janela, caso ainda não a tenha. As restantes abas não são relevantes, pelo que pode premir o botão “Ok” para criar o pedido de assinatura de certificado.

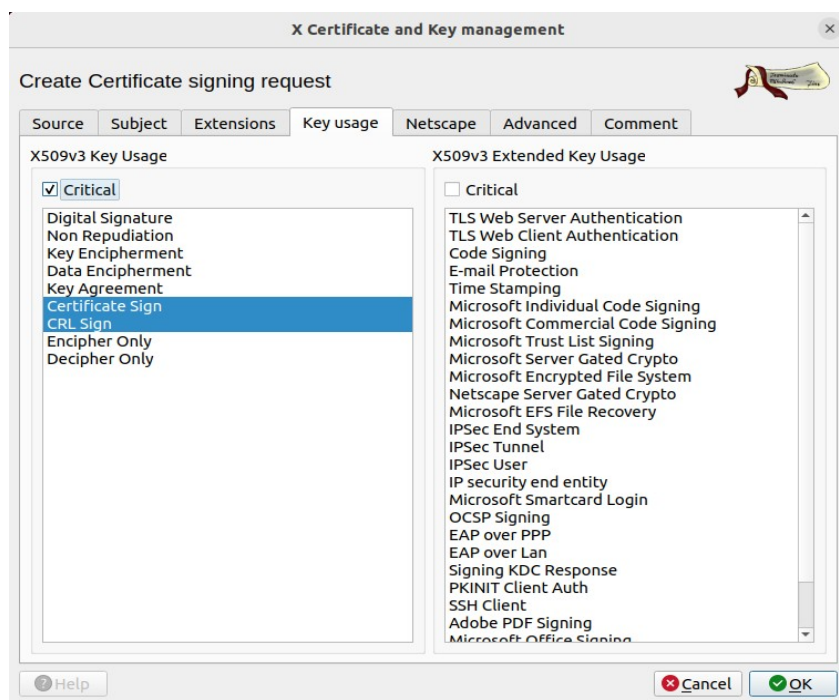


Figura 8: Aba Key Usage para a criação de um pedido de assinatura de certificado para uma CA.

Agora é necessário exportar o pedido de assinatura de certificado para um ficheiro de modo a ser enviado para a CA raiz. Selecione o pedido que criou e prima o botão “Export”. Na janela que se abre, indique o nome para o ficheiro, garanta que o formato de exportação é o PEM, selecione a pasta onde pretende salvar o ficheiro e prima o botão “Ok”. Este pedido de certificado deverá ser importado no XCA da CA Raiz, que deve emitir o certificado e proceder à sua exportação para ser entregue à CA Intermédia.

4. Instalação do certificado

Depois de recebido o certificado para a sua CA Intermédia, é necessário proceder à instalação. Para esse efeito, no XCA da CA Intermédia, vá para a aba “Certificates”, prima o botão “Import” e faça a importação do certificado recebido. A figura 6 mostra a CA Intermédia com o certificado importado. Como pode observar pelas duas marcas V no certificado, existe a chave privada correspondente à pública que o certificado contém e trata-se do certificado de uma CA.

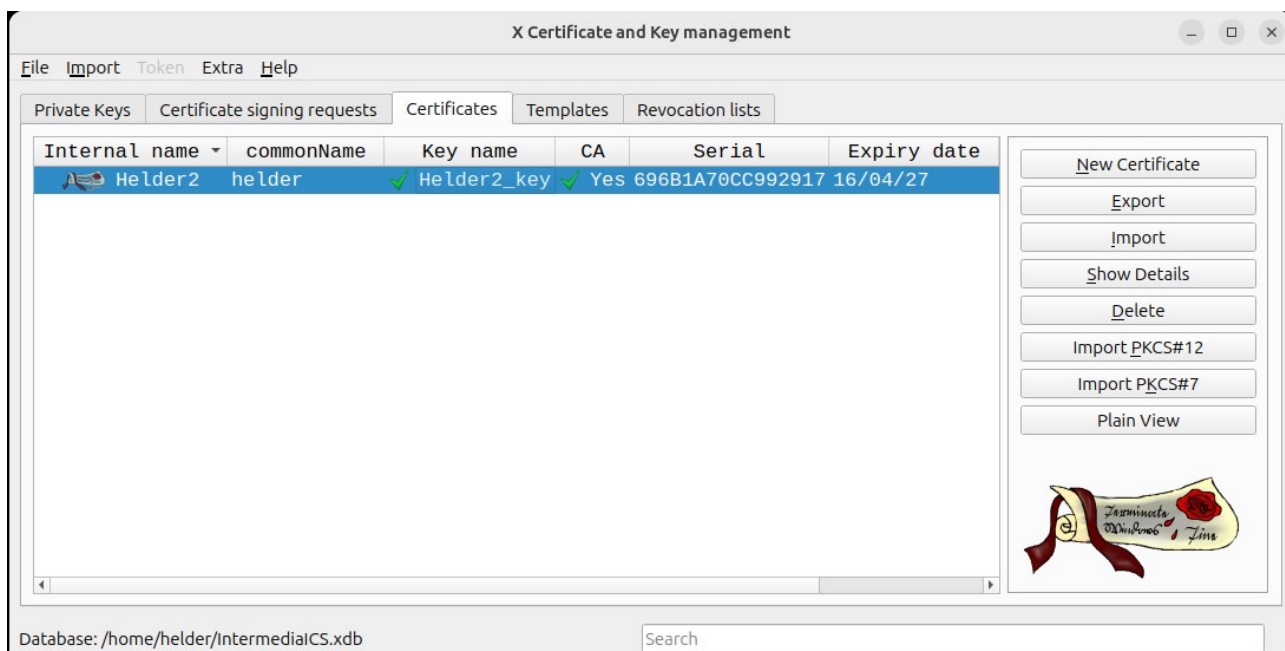


Figura 9: Certificado da CA Intermédia

5. Conclusão

Terminou a instalação e configuração da sua CA Intermédia. A partir de agora já pode emitir certificados para outras entidades.

Para garantir que as chaves privadas são do conhecimento exclusivo dos seus donos, a forma típica de emissão de certificados é a partir de pedidos de certificados. Para emitir um certificado para um cliente, deve ir para a aba “Certificate Signing Requests” e fazer a importação do pedido de certificado. A emissão de um certificado para um determinado pedido é feita selecionando o pedido de certificado, clicando com o botão do lado direito do rato para abrir o menu de contexto e selecionando a opção “Sign”. Na janela que se abre deve validar o conteúdo pretendido e fazer a emissão, se concordar, ou cancelar, se não concordar.

Como informação adicional, a criação de uma CA raiz é ainda mais simples do que a criação de uma CA Intermédia. Para a sua criação não existe nenhum pedido de certificado, mas apenas a criação de um certificado que se indica pretender auto-assinado e com o perfil de CA. Deve-se igualmente fornecer os dados de identificação da CA e em termos de extensões são também do perfil de CA, tal como foi feito para a CA Intermédia.

Apesar de agora você poder emitir certificados usando a sua CA Intermédia, estes não são reconhecidos e aceites por outras pessoas ou entidades, com exceção do docente. Explique porquê?

Produza um relatório incluindo capturas de ecrã que evidenciem as várias etapas do trabalho.